

# Security incident report

## Section 1: Identify the network protocol involved in the incident

The network protocols used in this incident were DNS and HTTP. We can see how the machine performs a DNS request to the DNS server for the IP address and then the DNS server responds with the IP address. Furthermore, the browser makes a HTTP GET request to the server to get content to display on the user's page on two different websites for yummyrecipesforme.com and greatrecipesforme.com

## Section 2: Document the incident

A malicious actor lured users to an alternative website with malware. They were able to log in and access the admin panel via brute force attack and correctly guessing the password. They embedded javascript code in the website that prompted users to download the file upon visiting the website and then were redirected to the alternative website. Customers complained to the helpdesk that their computers were running slower and the address of the website had changed. The security analyst team reconstructed the incident in a sandbox environment and observed that the user was redirected to another website. The browser initiated a DNS request to the DNS server and correctly returned the IP address for yummyrecipesforme and then the browser initiated an HTTP request using the IP address, however, the browser downloads malware on the website which redirects them to the alternative website where the browser initiates a DNS request for greatrecipesforme and then the browser initiates a HTTP GET request with the alternative IP address. We can see in the tcpdump logs where the machine requests the IP address at port "52444" to the DNS server and the DNS server responds with the IP address of "203.0.113.22". There happens some exchange between the browser and server as indicated by the Flags[S] on port "36086" and the browser makes a HTTP GET Request to the server at 14:18:36. However, we notice that the user is redirected to the alternative website and the browser makes a DNS request on the port "52444" and the server responds with the DNS address of "192.0.2.17". The machine attempts to exchange information with the web server and makes a HTTP GET

Request at 14:25:29 to the alternative website.

### **Section 3: Recommend one remediation for brute force attacks**

Remediations recommended are enforcing strong passwords because of the current incident where there were weak passwords and the hacker was able to log in via brute force. Furthermore, we need to monitor login attempts as multiple log in attempts can be suspicious and may indicate an attempt of brute force. We also need to limit the number of login attempts. It is recommended we limit to 3-5 attempts and then the user is locked out for a certain period of time. Another security measure can be to implement 2FA which requires additional authentication such as sending an OTP (One time password) to the user's email/phone. Furthermore, we need to disallow previous passwords from being used since the attacker was able to use a default password to log into the website.